

# FOOD RESCUE AGENT

## Documentazione legale di progetto

*Sicurezza alimentare (HACCP) nelle donazioni e protezione dei dati personali (GDPR)*

**Gruppo di lavoro legale**

Anna De Maio, Alessia De Michele

Ottobre 2026

## 1. Introduzione

Food Rescue Agent è un sito web contro lo spreco alimentare che mette in contatto chi ha eccedenze alimentari con i centri di raccolta, attraverso una mappa dei centri, la gestione delle donazioni e un agente AI di supporto. Dal punto di vista legale il progetto si colloca su due fronti distinti:

- **Sicurezza alimentare e donazioni:** quali norme regolano la cessione gratuita di alimenti e chi risponde di cosa lungo la filiera della donazione (HACCP, Legge Gadda, Terzo Settore).
- **Privacy e protezione dei dati:** quali obblighi derivano dal GDPR per un sistema che prevede registrazione e login degli utenti.

Il presente documento riunisce i due ambiti in un unico riferimento per il gruppo di lavoro e per le altre aree del progetto (sviluppo del sito e progettazione del database), che dovranno recepire i requisiti qui descritti.

## 2. Sicurezza alimentare e donazioni (HACCP)

### 2.1 Quadro normativo di riferimento

Le leggi che regolamentano questo settore si muovono su due livelli, europeo e italiano.

#### Livello europeo: la base della sicurezza alimentare

- **Regolamento (CE) n. 178/2002.** È la pietra miliare della legislazione alimentare europea. Stabilisce i principi generali della sicurezza alimentare, l'obbligo di tracciabilità e definisce la responsabilità legale di chiunque immetta sul mercato o distribuisca alimenti a terzi, anche a titolo gratuito.
- **Regolamento (CE) n. 853/2004.** Disciplina l'igiene dei prodotti alimentari e impone l'obbligo di applicare le procedure basate sui principi del sistema HACCP per tutte le attività commerciali e di ristorazione.

#### Livello nazionale: donazioni e Terzo Settore

- **Legge n. 166/2016 ("Legge Gadda").** È la legge cardine in Italia per la limitazione degli sprechi alimentari e la redistribuzione delle eccedenze. Facilita la donazione da parte delle imprese (ristoranti, supermercati, industrie) stabilendo che i prodotti alimentari possano essere ceduti gratuitamente per finalità di solidarietà sociale, chiarendo i limiti di responsabilità e valorizzando anche i prodotti oltre il Termine Minimo di Conservazione (TMC).
- **Decreto Legislativo n. 117/2017 (Codice del Terzo Settore).** Regola le organizzazioni di volontariato e gli enti caritativi che gestiscono i centri di raccolta, definendo i requisiti strutturali e operativi che questi devono possedere per ricevere e ridistribuire beni in sicurezza.
- **Manuale di corrette prassi operative per le organizzazioni caritative (validato dal Ministero della Salute).** È il documento tecnico ufficiale a cui i centri di raccolta e le associazioni devono attenersi per gestire ricezione, stoccaggio e distribuzione delle derrate alimentari nel pieno rispetto delle norme igienico-sanitarie.

### 2.2 Responsabilità del donatore: buona fede e responsabilità limitata

La Legge Gadda stabilisce il principio della responsabilità limitata e di buona fede:

- Il donatore è responsabile della sicurezza del cibo fino al momento della cessione, cioè garantisce di aver rispettato l'HACCP e le temperature fino a quando lo consegna all'ente.
- Se il cibo viene ceduto nel rispetto delle norme igieniche e ricevuto da enti che a loro volta seguono i protocolli di corretta prassi, il donatore è tutelato da eventuali responsabilità civili o penali derivanti da cattiva conservazione successiva o consumo improprio, a meno che non vi sia dolo o colpa grave.

## 2.3 Riepilogo per attore

| Attore                                         | Cosa deve garantire                                                                                                        | Riferimento                                 |
|------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|---------------------------------------------|
| Donatore (ristorante, supermercato, industria) | Rispetto di HACCP e temperature fino alla cessione; tracciabilità del prodotto ceduto                                      | Reg. (CE) 178/2002 e 852/2004; L. 166/2016  |
| Centro di raccolta / ente caritativo           | Requisiti strutturali e operativi per ricevere e ridistribuire; corretta gestione di ricezione, stoccaggio e distribuzione | D.Lgs. 117/2017; Manuale di corrette prassi |
| Piattaforma Food Rescue Agent                  | Facilitare l'incontro tra donatori e centri nel rispetto di questo quadro (vedi sezione 4)                                 | Principi generali, Reg. (CE) 178/2002       |

## 3. Privacy e protezione dei dati personali (GDPR)

Il sito prevede registrazione e login degli utenti, quindi tratta dati personali (ad esempio email e nome utente). Di seguito i requisiti di conformità da rispettare.

### 3.1 Informativa sulla privacy

- **Cosa prevede:** prima che l'utente completi la registrazione creando un account, il sistema deve mettergli a disposizione un'informativa chiara, concisa e facilmente accessibile (art. 13 GDPR, Regolamento UE 2016/679).
- **Cosa inserire:** chi è il titolare del trattamento, quali dati vengono raccolti (es. email, nome utente), le finalità del trattamento (es. gestione dell'account, erogazione del servizio), i tempi di conservazione e i diritti dell'utente.
- **Buona prassi tecnica:** inserire in fase di registrazione una casella di spunta (checkbox) non pre-flaggata, con un link testuale che rimanda all'informativa completa.

### 3.2 Base giuridica del trattamento

- **Cosa prevede:** secondo l'art. 6 GDPR, ogni trattamento di dati personali deve fondarsi su una base giuridica valida.
- **Applicazione per il login:** per la creazione e la gestione di un account utente la base giuridica principale è solitamente l'esecuzione di un contratto o di misure precontrattuali richieste dall'interessato (art. 6, par. 1, lett. b).
- **Newsletter e profilazione:** se si intende inviare newsletter o fare profilazione, occorre raccogliere un consenso specifico, distinto e facoltativo.

### 3.3 Minimizzazione dei dati

- **Cosa prevede:** l'art. 5 GDPR stabilisce che i dati personali devono essere "adeguati, pertinenti e limitati a quanto necessario rispetto alle finalità" (data minimization).
- **Applicazione pratica:** in fase di registrazione richiedere solo i dati strettamente necessari all'erogazione del servizio (es. email e password). Evitare di rendere obbligatori campi superflui (genere, data di nascita, numero di telefono, indirizzo) a meno che non siano realmente indispensabili al funzionamento dell'applicazione.

### 3.4 Sicurezza delle credenziali e dei dati (security by design)

- **Cosa prevede:** l'art. 32 GDPR impone misure tecniche e organizzative adeguate a garantire un livello di sicurezza idoneo al rischio (crittografia, riservatezza e integrità dei sistemi).
- **Hashing delle password:** le password non devono mai essere salvate in chiaro nel database. È obbligatorio usare algoritmi di hashing sicuri e robusti con salt (es. bcrypt, Argon2, PBKDF2).
- **Trasmissione sicura:** il traffico tra client e server deve viaggiare esclusivamente su protocollo cifrato (HTTPS/TLS).
- **Accessi logici:** adottare registri e controlli sugli accessi logici ai sistemi informatici di gestione dei dati.

### 3.5 Diritti degli utenti e cancellazione (diritto all'oblio)

- **Cosa prevede:** gli articoli dal 15 al 22 GDPR riconoscono agli utenti diversi diritti, tra cui accesso ai propri dati, rettifica e cancellazione.
- **Applicazione pratica:** dalla dashboard utente, o tramite richiesta, l'utente deve poter eliminare facilmente il proprio account. Alla cancellazione i dati personali vanno rimossi dai sistemi attivi o anonimizzati, salvo i dati che la legge impone di conservare per obblighi fiscali o civilistici (es. 10 anni per eventuali transazioni commerciali, art. 2220 del Codice Civile).

## 4. Requisiti operativi per il progetto

La tabella traduce il quadro normativo in indicazioni per i gruppi che sviluppano il sito e il database.

| Rif. | Requisito                                                                                                                                 | Fonte        |
|------|-------------------------------------------------------------------------------------------------------------------------------------------|--------------|
| R1   | Prima della registrazione, mostrare l'informativa privacy, con checkbox non pre-flaggata e link al testo completo                         | Art. 13 GDPR |
| R2   | Nell'informativa indicare titolare, dati raccolti, finalità, tempi di conservazione, diritti                                              | Art. 13 GDPR |
| R3   | Usare come base giuridica del login l'esecuzione di un contratto; prevedere consenso separato e facoltativo per newsletter o profilazione | Art. 6 GDPR  |
| R4   | Richiedere in registrazione solo i dati necessari (es. email e password)                                                                  | Art. 5 GDPR  |
| R5   | Salvare le password con hash e salt (bcrypt, Argon2 o PBKDF2), mai in chiaro                                                              | Art. 32 GDPR |

| Rif. | Requisito                                                                                                                       | Fonte                            |
|------|---------------------------------------------------------------------------------------------------------------------------------|----------------------------------|
| R6   | Servire il sito esclusivamente su HTTPS/TLS                                                                                     | Art. 32 GDPR                     |
| R7   | Tenere registri e controlli sugli accessi logici                                                                                | Art. 32 GDPR; Garante            |
| R8   | Offrire all'utente la cancellazione dell'account; rimuovere o anonimizzare i dati, conservando solo quelli con obbligo di legge | Artt. 15-22 GDPR; art. 2220 c.c. |
| R9   | Gestire le donazioni nel rispetto della tracciabilità e della responsabilità di chi cede alimenti, anche a titolo gratuito      | Reg. (CE) 178/2002               |
| R10  | Ricondurre la donazione a finalità di solidarietà sociale verso enti del Terzo Settore che seguono le corrette prassi operative | L. 166/2016; D.Lgs. 117/2017     |

## 5. Fonti normative di riferimento

- **Regolamento (CE) n. 178/2002:** principi generali di sicurezza alimentare, tracciabilità, responsabilità.
- **Regolamento (CE) n. 852/2004:** igiene dei prodotti alimentari e procedure HACCP.
- **Legge n. 166/2016 (Legge Gadda):** limitazione degli sprechi e redistribuzione delle eccedenze.
- **D.Lgs. n. 117/2017 (Codice del Terzo Settore):** organizzazioni di volontariato ed enti caritativi.
- **Manuale di corrette prassi operative per le organizzazioni caritative:** validato dal Ministero della Salute.
- **Regolamento UE 2016/679 (GDPR):** in particolare artt. 5 (principi), 6 (basi giuridiche), 13 (informativa), 15-22 (diritti, tra cui art. 17 cancellazione) e 32 (sicurezza del trattamento).
- **D.Lgs. n. 196/2003 (Codice della Privacy) e successive modifiche:** normativa nazionale di adeguamento al GDPR.
- **Codice Civile, art. 2220:** conservazione delle scritture contabili (10 anni).
- **Garante per la protezione dei dati personali:** linee guida e provvedimenti su sicurezza delle password, tracciamento degli accessi logici e trasparenza delle informative online.